Getamazednow AI
A GETAMAZEDNOW COMPANY

A D S R A

Australian Digital Sovereignty Reference Architecture



Leveraging global cloud and AI platforms while retaining Australian control of data, identity, cryptography, operations cryptography, operations and AI — in line with Australian regulatory and business obligations.

Executive Briefing — for Board, Risk Committee and Executive Technology Leadership

Author: Duane · Draft v0.3 · October 2026

THE REGULATORY CLOCK IS ALREADY RUNNING

Why now: sovereignty obligations have moved from policy to enforcement — and the AI dates are close

1 Jul 2026

CPS 230 transition complete

Pre-existing provider contracts had to comply by the earlier of renewal or 1 Jul Jul 2026 — that date has passed. APRA's APRA's targeted amendments (30 Apr 2026) give narrow relief for non-traditional traditional providers only; the 24- and 72-72-hour notification clocks are unchanged. unchanged.

APRA CPS 230 and amendments

30 Apr 2026

APRA's first AI expectations

Boards of banks, insurers and super trustees are asked for an AI inventory, human involvement in high-risk decisions, a mapped AI supply chain, tested exit strategies and continuous monitoring. APRA found governance is not keeping pace with adoption.

APRA letter on AI, 30 Apr 2026

10 Dec 2026

Automated-decision transparency

Under ten weeks away. Privacy policies must disclose automated decisions that significantly affect individuals. OAIC's final guidance (Sep 2026) reaches programs that substantially inform a human decision — review in the loop is not an exit [Position].

APP 1.7–1.9; OAIC guidance

Early 2027

Mandatory AI Standards announced

Legislation expected early 2027. Defined so far for large AI data centres and AI-training use of creative work — not yet for how enterprises use AI. Today's duty is unchanged: evidence control under existing law.

PM speech, 15 Jul 2026

Also moving — SOCI: enhanced risk-management rules commenced 10 Jun 2026 for specified asset classes (12/24-month windows); Tranche 2 reforms are proposed, not law. Next: proposed, not law. Next: what else is moving.

ALSO MOVING

What else is in force, in consultation or announced

10 Jun 2025

Privacy tort live

Statutory tort for serious invasions of privacy under the Privacy and Other Legislation Amendment Act 2024; tiered penalties and stronger OAIC powers already apply.

Privacy Act 1988 (Cth), as amended

10 Jun 2026

Enhanced CIRMP Rules

SOCI risk-management uplift for specified asset classes — electricity, gas, water, liquid fuel, freight and others — with 12- and 24-month implementation windows. Tranche 2 reforms (provider and supply-chain duties) are proposed, not law.

CISC / Home Affairs

15 Dec 2026

Public-sector AI assurance

Commonwealth agencies must have AI impact assessments in place for in-scope use cases by 15 Dec 2026 (DTA policy v2.0). A Joint Select Committee on AI — data sovereignty in its terms — is due to report 30 Nov 2026.

DTA policy v2.0; Parliament

2025–26

AI policy consolidates

Guidance for AI Adoption (Oct 2025) superseded the Voluntary AI Safety Standard; the National AI Plan (Dec 2025) and an advisory AI Safety Institute followed. Data-centre expectations (Mar 2026) name national security and data sovereignty.

DISR / National AI Centre

Watch: the Children's Online Privacy Code (draft; must be registered by 10 Dec 2026) and the Hosting Certification Framework refresh — neither is an obligation today. obligation today.

Sovereignty is treated as a compliance checkbox — not an architecture

THE EXPOSURE

Jurisdictional reach.
The US CLOUD Act (2018) can compel US-headquartered providers to produce data regardless of where it is stored — residency alone is not sovereignty.

Concentration.
Critical operations increasingly run on a small number of global hyperscale and SaaS providers — exactly the dependency CPS 230 asks boards to evidence and control — and, since APRA's AI letter, the AI model providers behind them.

AI opacity.
Prompts, embeddings, telemetry and fine-tuning data flow through model supply chains that most enterprises cannot map, audit or constrain today.

THE GAP

No cohesive reference model.
TOGAF gives method, SABSA gives security attributes, cloud well-architected frameworks give workload guidance, the ISM gives controls — none treats digital sovereignty as a first-class enterprise architecture domain with capabilities, maturity levels and measures.

The consequence.
Sovereignty decisions are made workload-by-workload, late, and without an investment logic the Board can govern. Risk is accepted implicitly rather than priced explicitly.

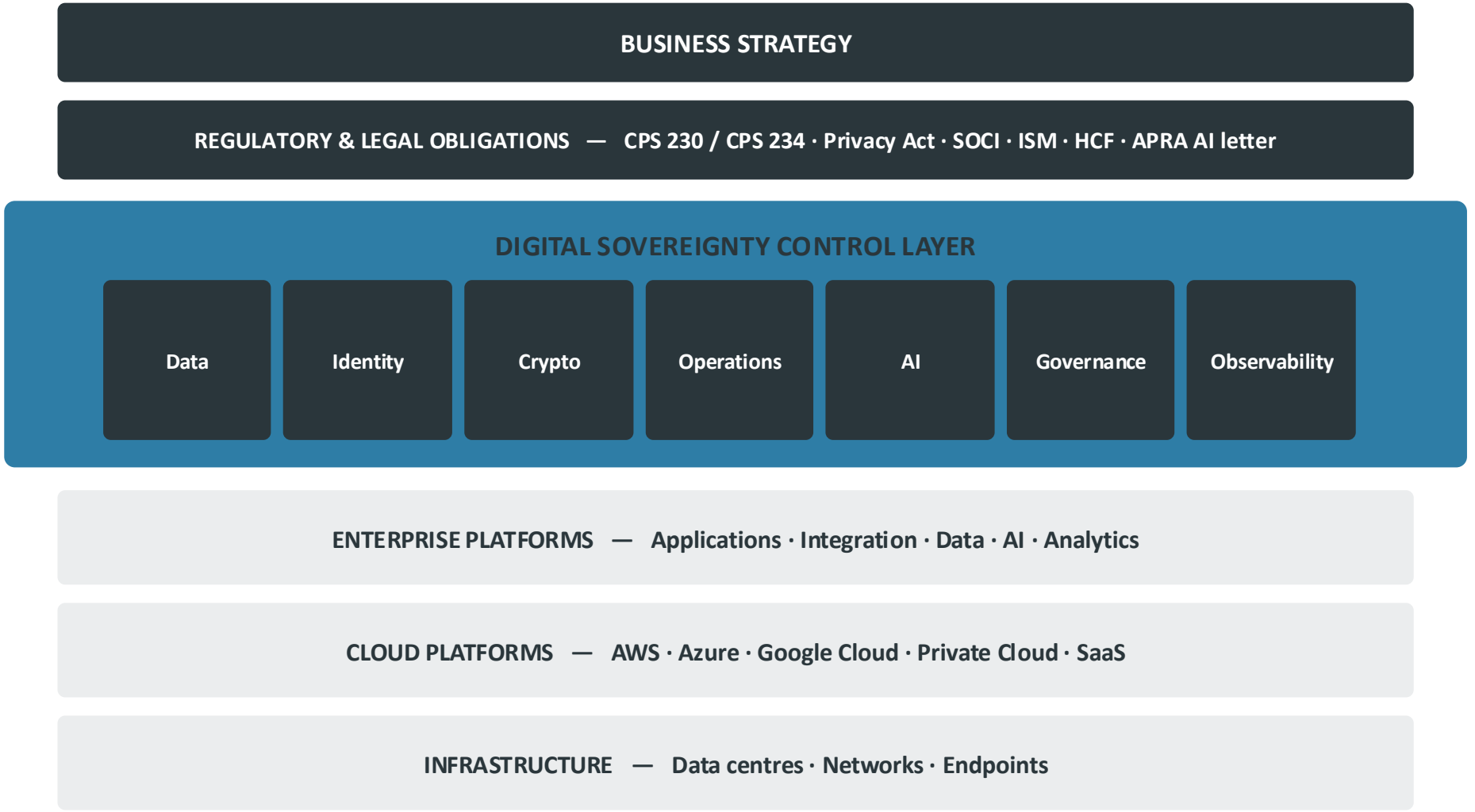
The opportunity.
Define the reference architecture the market is converging on — before it is defined for us.

ADSRA: sovereignty as an enterprise architecture capability

A reference architecture enabling Australian organisations to use global cloud and AI platforms while retaining control over data, identity, cryptography, operations and AI — expressed as control domains, capabilities, reference patterns, a maturity model and measurable KRIs.

Framework	What it provides	What it does not provide
TOGAF / ADM	Enterprise architecture method and content metamodel	No sovereignty domain, controls or jurisdictional lens
SABSA	Business-attribute-driven security architecture	Not cloud/AI-era specific; no AU regulatory mapping
AWS / Azure Well-Architected	Workload-level design guidance per cloud	Single-vendor scope; not an enterprise operating model
ISM / Essential Eight (ASD)	Baseline cyber controls and hardening	Controls catalogue, not an architecture or investment logic
ADSRA (proposed)	Sovereignty control domains, 20 capabilities, maturity model, KRIs, AU regulatory mapping, AI sovereignty patterns	Method-neutral: designed to plug into TOGAF/SABSA practice

Sovereignty sits above technology — not below it



Every workload below the line inherits the controls of the sovereignty layer — policy is enforced by platform, evidenced by telemetry, and governed like any other enterprise capability.

Seven questions every board should be able to answer

1 DATA

Who can legally compel access to our information?

2 IDENTITY

Who is acting, from where, and with what privilege?

3 CRYPTOGRAPHIC

Who controls the keys that control control trust?

4 OPERATIONAL

Who administers production — and and from which jurisdiction?

5 AI

Where do prompts, embeddings, inference and training occur?

6 GOVERNANCE

Is compliance enforced by the platform, or by a policy PDF?

7 OBSERVABILITY

Can we prove, audit and measure sovereignty — daily?

Each pillar carries defined control objectives, reference patterns and measurable key risk indicators.

Data, identity and cryptography: control before consumption

1 · DATA SOVEREIGNTY

- Classification with sovereignty tiers (Low → Critical)
- Residency & cross-border transfer controls
- Tokenisation and data loss prevention
- Privacy impact assessments in delivery lifecycle

Classification drives everything: each tier receives different architectural treatment.

2 · IDENTITY SOVEREIGNTY

- Australian-controlled enterprise IdP & federation
- Zero Trust: continuous verification, least privilege
- MFA, conditional access, PIM/PAM
- Identity governance & recertification

Every request answers: who, what, why, when, from where, at what risk score.

3 · CRYPTOGRAPHIC SOVEREIGNTY

- Customer-managed keys (CMK), BYOK / HYOK HYOK
- HSM-backed roots of trust
- Client-side encryption for critical tiers
- Key rotation and crypto-agility (PQC-ready)

Encryption is the last defence against jurisdictional uncertainty — if you hold the keys.

Operations, AI, governance and observability: control in motion

4 · OPERATIONAL

- Australian operations, SOC & incident response
- Administrative separation of duties
- Privileged session recording
- Jurisdiction-aware break-glass

5 · AI

- Prompt, embedding, inference & training sovereignty
- LLM gateway + approved model registry (the AI inventory)
- RAG governance & PII detection
- Output validation & audit
- Decision assurance: impact assessment, explainability, human oversight

6 · GOVERNANCE

- Policy-as-code (Azure Policy, SCPs, OPA)
- IaC validation in pipelines
- Security & compliance guardrails
- Every deployment inherits compliance
- Aligned to AS ISO/IEC 42001 (AI management system)

7 · OBSERVABILITY

- Central logging, SIEM, UEBA
- AI observability & model telemetry
- Immutable audit trails
- Compliance dashboards & regulatory reporting

Observability is the underdeveloped pillar — if you cannot continuously measure sovereignty, you cannot claim it. This is where AI observability practice extends naturally into sovereignty assurance.

Not everything needs a fortress: classification prices the control

Data asset	Sovereignty tier	Architectural treatment
Product catalogue	★ Low	Global CDN, provider-managed encryption, standard logging
Pricing & promotions	★★ Medium	AU-region hosting, CMK optional, DLP monitoring
Loyalty behaviour	★★★ High	AU residency, CMK, tokenised identifiers, PIA required
Customer profiles	★★★ High	AU residency, CMK, conditional access, ADM-transparency review
Payment cards	★★★★ Critical	Tokenised (PCI DSS), HSM-backed keys, AU SOC, client-side encryption

Checkout (Critical): Azure Australia East, customer-managed keys, tokenised payments, Australian SOC.

Catalogue (Low): runs globally on public CDN — no personal information, no sovereignty premium paid.

INDUSTRY LENSES

The same architecture, four regulatory postures — with full Utilities & Education blueprints in the Technical Reference (§10.5–10.6)

BANKING

CPS 230 critical operations & tolerance levels; CPS 234 information security; 24-hour security; 24-hour notification of tolerance breaches, 72-hour for material incidents. incidents. Sovereignty tiers map directly to the critical-operations register. APRA's AI APRA's AI letter adds AI inventory, supply-chain and exit expectations.

FINANCIAL SERVICES & SUPER

Material service provider registers, exit and contingency plans, fourth-party visibility. Sovereignty KRIs give Risk Committees a quantified view of provider concentration and jurisdictional exposure.

RETAIL

Privacy tort and tiered penalties raise the cost of loyalty and profile data breaches; ADM transparency (Dec 2026, OAIC guidance out) constrains pricing and personalisation AI. PCI tokenisation becomes the Critical-tier pattern.

HEALTHCARE

My Health Records Act requires records to be held and processed in Australia; SOCI Australia; SOCI covers the healthcare sector; sensitive health data sits at Critical tier Critical tier with client-side encryption and AU-only AI inference.

Utilities & education — where regulation bites hardest, and control inheritance pays back fastest

UTILITIES · OBLIGATIONS

SOCI Act — energy, water, gas: CIRMP duties (enhanced rules from 10 Jun 2026) and mandatory incident reporting. ISM / Essential Eight across the OT/IT boundary. Sovereignty tiers map to the critical-infrastructure register, so tolerance and reporting duties inherit automatically.

UTILITIES · AI ASSURANCE

Demand-forecasting, outage and asset-failure models route via the AI gateway with impact assessment, registry pinning and human oversight. No model directly controls OT actuation — recommendations stay advisory to the control room.

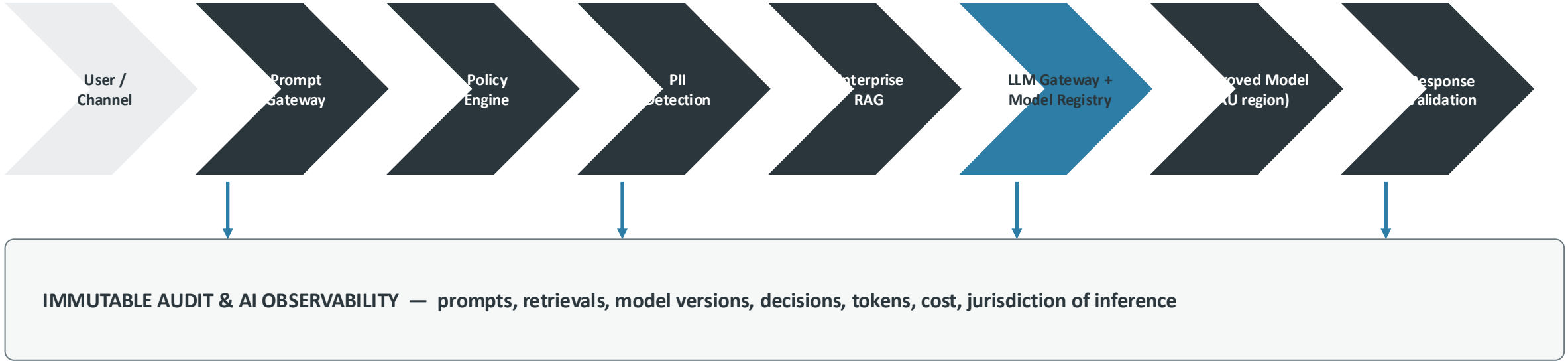
EDUCATION · OBLIGATIONS

Privacy Act — student personal and sensitive data. State frameworks (e.g. NSW AI Assurance Framework, 2022) and the National assurance framework for public institutions. Child-safety duties where learners are minors (draft Children's Code, targeted 10 Dec 2026); student, assessment and research data sit at the top tiers.

EDUCATION · AI ASSURANCE

Tutoring, marking and admissions copilots run on governed RAG with human human oversight and a documented contestability path. Automated marking never marking never issues a final grade without human ratification; ADM-transparency transparency disclosures apply from Dec 2026.

AI sovereignty: the model is only one component



- **Prompt sovereignty —** No raw prompts leave the enterprise boundary unfiltered
- **Inference & training sovereignty —** Model registry pins approved models, versions and regions — including an Australian sovereign-model option where in-region frontier access lags
- **Embedding & RAG sovereignty —** Vector stores and retrieval corpora remain in-region, access-governed
- **Output governance —** Responses validated, watermarked where required, and evidenced. Decision assurance adds impact assessment, explainability and contestability for automated decisions

Twenty capabilities a Board can fund, measure and govern

DATA

Classification · Residency · Privacy Engineering

AI

AI Gateway · Prompt Management · RAG Governance · Model Registry

IDENTITY

IAM · Privileged Access (PAM) · Federation

GOVERNANCE

Policy-as-Code · Compliance Automation

CRYPTO

Key Management · HSM Services

OBSERVABILITY

Telemetry · Immutable Audit · AI Monitoring

OPERATIONS

Australian Operations · Incident Response

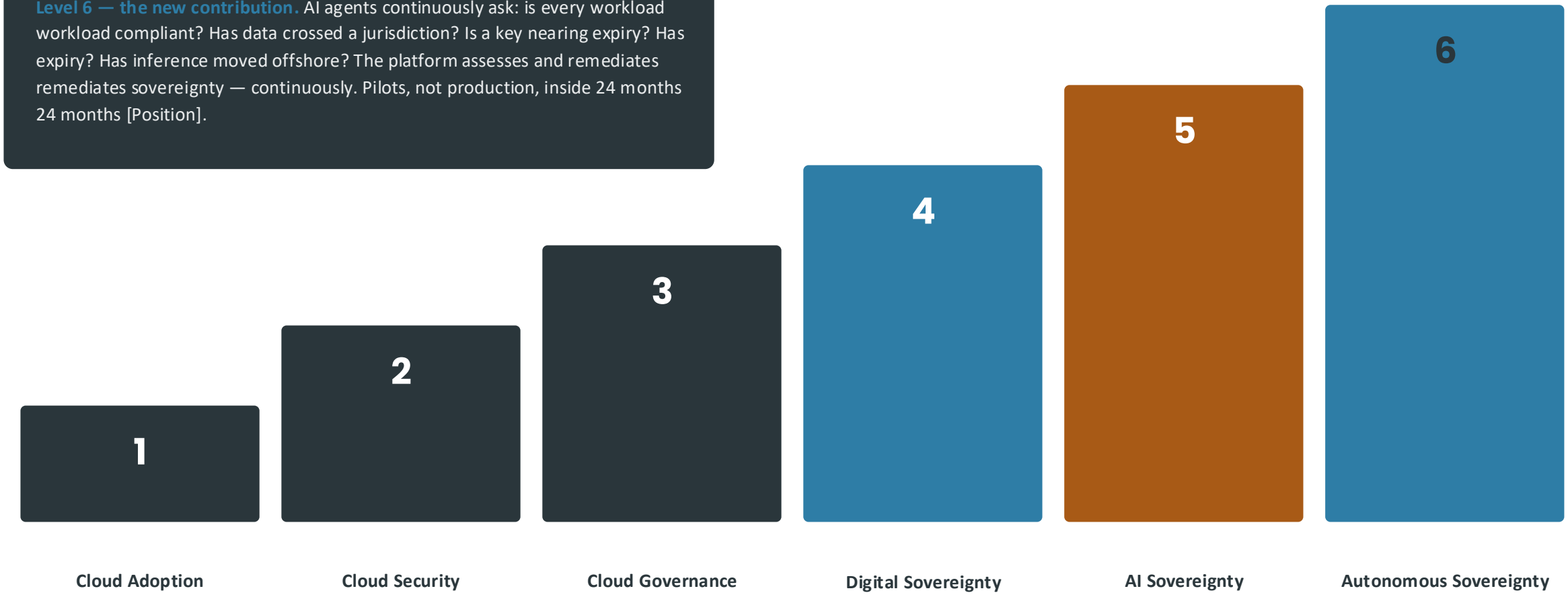
RISK

Continuous Assurance

Each capability is defined with control objectives (ADSRA-XX-nn), owner, reference pattern, target maturity and KRIs — detailed in the Technical Reference.

From cloud adoption to autonomous sovereignty

Level 6 — the new contribution. AI agents continuously ask: is every workload workload compliant? Has data crossed a jurisdiction? Is a key nearing expiry? Has expiry? Has inference moved offshore? The platform assesses and remediates remediates sovereignty — continuously. Pilots, not production, inside 24 months 24 months [Position].



Most enterprises sit at Levels 2–3 today [Position]. ADSRA now targets Level 4 in ~15 months and Level 5 in ~24 (was 36).

Sovereignty priced as risk reduction, speed and trust

1. **Penalty & tort exposure avoided.** Privacy penalties now reach the greater of $50m or 3× the benefit (30% of turnover if the benefit can't be determined); the statutory tort adds claims for serious invasions of privacy that can multiply where many people are affected [Position].

2. **Regulatory speed.** Pre-approved sovereignty patterns cut architecture and risk-approval cycle times for new cloud and AI workloads.

3. **Concentration risk visibility.** CPS 230 provider registers plus sovereignty KRIs give Risk Committees a quantified exit and substitution posture.

4. **Licence to deploy AI.** Evidenced AI sovereignty (gateway, registry, audit) is becoming the becoming the precondition for board approval of customer-facing AI — APRA's April 2026 APRA's April 2026 letter says the same.

MEASURES THAT MATTER (KRIs)

- % Critical/High data under customer-managed keys
- % privileged sessions administered from Australia (and recorded)
- % AI inference executed in-region via the LLM gateway
- % deployments passing policy-as-code gates first time
- Mean time to detect a cross-jurisdiction data movement
- % critical operations with tested exit / substitution plans

Reported quarterly to the Architecture Board and Risk Committee — trend, target, tolerance.

Sovereignty is not free: the trade-offs, stated plainly

COSTS & RISKS OF DOING THIS

- Sovereign controls (HYOK, client-side encryption, AU-only ops) add cost and can break native cloud features
- In-region AI can lag frontier model availability — a real capability trade — narrowing as Australian sovereign model and compute options mature [Position]
- Over-classification taxes low-risk workloads and slows delivery
- Skills scarcity: policy-as-code and AI governance engineering talent is thin

RISKS OF NOT DOING THIS

- Unpriced jurisdictional exposure across data, keys and AI supply chains
- CPS 230 / SOCI findings, remediation programs, and potential capital add-ons
- Privacy tort and tiered-penalty exposure concentrated in unclassified data estates
- AI adoption stalls — every use case re-litigates risk from first principles

The managed position: tier the estate, pay the sovereignty premium only where classification demands it, and measure the residual risk you consciou sly accept.

Three horizons to Level 4–5 — and what we ask of this Board

HORIZON 1 · 0–6 MONTHS

Foundations

- Sovereignty classification of Critical/High data estates
- Baseline maturity assessment against the 20 capabilities
- Stand up LLM gateway + model registry (AI inventory) for all AI pilots
- Sovereignty KRIs on the Risk Committee dashboard; ADM disclosures drafted before 10 Dec 2026

HORIZON 2 · 6–15 MONTHS

Enforcement

- CMK/HSM coverage for Critical tier; policy-as-code gates in all pipelines
- Australian operations & privileged session recording for critical ops
- RAG governance and PII detection in production AI
- Exit / substitution plans tested for material providers (incl. AI providers)

HORIZON 3 · 15–24 MONTHS

Assurance

- Continuous sovereignty assurance (Level 5 → 6 pilots)
- Agentic compliance monitoring across clouds
- Sovereignty posture in annual report & regulator engagement
- Publish and iterate the reference architecture

THE ASK: endorse ADSRA as the enterprise sovereignty reference; fund Horizon 1 — starting with the sprint to 10 Dec 2026; appoint an accountable executive accountable executive owner; receive sovereignty KRIs quarterly.

References

- APRA, Prudential Standard CPS 230 Operational Risk Management (in force 1 Jul 2025; targeted amendments final 30 Apr 2026, effective 1 Jul 2026) and CPG 230.
- APRA, Prudential Standard CPS 234 Information Security (2019).
- Privacy Act 1988 (Cth); Privacy and Other Legislation Amendment Act 2024 (Cth) — assent 10 Dec 2024; statutory tort by Jun 2025; APP 1.7–1.9 ADM transparency from 10 Dec 2026.
- Privacy Legislation Amendment (Enforcement and Other Measures) Act 2022 (Cth) — penalty regime.
- Security of Critical Infrastructure Act 2018 (Cth) and CIRMP Rules — 11 sectors incl. financial services, healthcare, energy, data storage.
- ASD/ACSC, Information Security Manual (ISM) and Essential Eight; IRAP assessment program.
- DTA / Dept of Home Affairs, Hosting Certification Framework — Certified Strategic / Certified Assured (applies to new contracts from 30 Jun 2022).
- DISR / National AI Centre — Voluntary AI Safety Standard (2024); Guidance for AI Adoption (Oct 2025); National AI Plan (Dec 2025); AI Safety Institute (operational 2026; advisory); data-centre expectations (23 Mar 2026).
- My Health Records Act 2012 (Cth) — Australian data-handling requirements for My Health Record information.
- Clarifying Lawful Overseas Use of Data (CLOUD) Act 2018 (US) — extraterritorial production obligations on US providers.
- Also: APRA Letter to industry on AI (30 Apr 2026); PM speech "AI in Australia's interests" (15 Jul 2026); OAIC APP 1.7–1.9 resources (Sep 2026); DTA AI policy v2.0; Enhanced CIRMP Rules 2026 and SOCI Tranche 2 consultation (proposals only); Joint Select Committee on AI; Children's Online Privacy Code (draft).
- ISO/IEC 42001:2023 AI Management Systems; NIST AI Risk Management Framework 1.0.
- Australian, state and territory governments, National framework for the assurance of artificial intelligence in government (v1.0, 21 June 2024), based on Australia's AI Ethics Principles (DISR 2019); AS ISO/IEC 23894:2023; AS ISO/IEC 38507:2022.

Full citations, URLs and an evidence register appear in the ADSRA Technical Reference (companion document).